

Aula 3 (Módulo 03) — TCP, UDP e Portas

1. O problema que porta resolve

Um computador tem **um único IP** (ou poucos), mas pode rodar **dezenas** de serviços de rede ao mesmo tempo (servidor web, servidor SSH, banco de dados...). Como o tráfego que chega sabe para qual desses serviços ir?

A resposta é a **porta**: um número de 0 a 65535 que identifica, dentro de um IP, **qual serviço/canal específico** deve receber aquele tráfego. Já usamos isso, sem formalizar, no Módulo 01 (Aula 6, com `ss -tuln`).

```
IP + Porta = "endereço completo" de um serviço
192.168.1.10:22   → SSH nessa máquina
192.168.1.10:443  → servidor web (HTTPS) na MESMA máquina
```

Portas conhecidas (well-known ports)

Certas portas têm uso padronizado, definido pela IANA (organização que administra esses números):

Porta	Serviço
22	SSH
23	Telnet (antigo, sem criptografia — evitar)
25	SMTP (envio de e-mail)
53	DNS
80	HTTP
443	HTTPS
3389	RDP (Remote Desktop, Windows)

Por que importa para segurança: reconhecer essas portas de cor é uma habilidade básica de qualquer analista — ver tráfego na porta 3389 vindo da internet para um servidor, por exemplo, já é um sinal de alerta (RDP exposto diretamente à internet é uma das causas mais comuns de comprometimento por ransomware em ambientes reais, através de brute force ou exploração de vulnerabilidade). Mas atenção: **um serviço pode rodar em qualquer porta** — um atacante pode configurar seu C2 (Módulo 00, Aula 3) para usar a porta 443, justamente para o tráfego malicioso se camuflar entre o tráfego HTTPS legítimo, que é muito mais difícil de bloquear por completo. Ou seja: a porta é uma **pista forte**, mas nunca prova absoluta do que está de fato acontecendo ali.

2. TCP (Transmission Control Protocol) — comunicação confiável

TCP garante que os dados **cheguem completos, na ordem certa, e sem erro** — ele confirma o recebimento de cada pedaço de dado, e reenvia automaticamente o que se perde no caminho. Isso tem um custo: mais "conversa" entre as duas pontas antes mesmo dos dados começarem a fluir.

O "aperto de mão" de três vias (Three-Way Handshake)

Antes de trocar qualquer dado de verdade, TCP estabelece a conexão assim:

Cliente	→ SYN	→ Servidor	("quero conectar")
Cliente	← SYN-ACK	← Servidor	("ok, aceito, e você?")
Cliente	→ ACK	→ Servidor	("confirmado, vamos conversar")

Só depois dessas três mensagens é que os dados de verdade começam a ser trocados. No final, a conexão é encerrada de forma organizada (com pacotes `FIN`).

Por que importa para segurança: o handshake TCP é a base de um ataque clássico chamado **SYN Flood** — um tipo de negação de serviço (DoS) onde o atacante envia muitos `SYN` e nunca completa o handshake, esgotando os recursos do servidor que ficam "esperando" a resposta. Ferramentas de análise de tráfego (Módulo 04, Wireshark/Zeek) mostram claramente handshakes incompletos como esse.

3. UDP (User Datagram Protocol) — comunicação "solta"

UDP **não** garante entrega, não confirma recebimento, não reordena — simplesmente envia o dado e segue em frente. É mais rápido e mais leve que TCP, exatamente por não ter esse controle extra.

Usado onde velocidade importa mais que garantia perfeita de entrega: streaming de vídeo/voz (VoIP), jogos online, e — muito importante para nós — **DNS** (a maioria das consultas DNS usa UDP, por serem pequenas e precisarem ser rápidas; veremos DNS com profundidade na próxima aula).

	TCP	UDP
Confiabilidade	Garante entrega/ordem	Não garante nada
Velocidade	Mais lento (overhead do handshake)	Mais rápido
Uso típico	Web (HTTP/HTTPS), SSH, e-mail	DNS, streaming, VoIP

4. Vendo isso na prática (revisão do Módulo 01)

```
ss -tulpn
```

Lembrando: `-t` = TCP, `-u` = UDP. Rodar isso mostra, lado a lado, quais serviços da sua máquina usam cada protocolo — normalmente você vai ver SSH (22) e servidores web (80/443) em TCP, e clientes DNS em UDP.

5. Conectando tudo

IP identifica a MÁQUINA

└ Porta identifica o SERVIÇO dentro da máquina

└ TCP: confiável, com handshake (SYN/SYN-ACK/ACK) – web, SSH

└ UDP: rápido, sem garantia – DNS, streaming

Com isso, você já consegue ler completamente uma linha de `ss -tulpn` ou de um log de conexão: **IP:porta, protocolo**, e o que isso normalmente significa.

6. Exercício prático

```
ss -tulpn | sort
```

Para cada linha, identifique: é TCP ou UDP? A porta é uma "well-known port" reconhecível (tabela da seção 1)? Se sim, faz sentido aquele serviço estar ali? Esse é exatamente o tipo de checagem de linha de base que fazemos repetidamente em Blue Team.

7. Recapitulando

- Porta identifica um serviço específico dentro de um IP; portas conhecidas (22, 53, 80, 443, 3389...) são pistas fortes, mas não prova absoluta.
- TCP é confiável (handshake SYN/SYN-ACK/ACK); base de ataques como SYN Flood.
- UDP é rápido, sem garantia de entrega; usado por DNS e streaming.
- `ss -tulpn` mostra, na prática, protocolo + porta + processo — a síntese desta aula com o Módulo 01.

Próxima aula

DNS — como nomes de domínio (como `google.com`) viram endereços IP, e por que DNS é, ao mesmo tempo, essencial e um dos vetores de ataque mais explorados (DNS tunneling, domínios maliciosos, typosquatting).

Fontes recomendadas

- **RFC 793 (atualizada pela RFC 9293) — "Transmission Control Protocol"**: especificação técnica oficial do TCP. <https://www.rfc-editor.org/rfc/rfc9293>
- **RFC 768 — "User Datagram Protocol"**: especificação técnica oficial do UDP. <https://www.rfc-editor.org/rfc/rfc768>
- **IANA — "Service Name and Transport Protocol Port Number Registry"**: registro oficial de portas conhecidas. <https://www.iana.org/assignments/service-names-port-numbers/service-names-port-numbers.xhtml>